Vulnerability Assessment Report

DownUnderNewsz Vulnerability Assessment Report

DownUnderNewsz (The Down Under News)
22 Arthur St
Fairfield VIC 3078, Australia

Flinders University
Sturt Road, Bedford Park SA 5042

October 5, 2026

Report Version: 1.0

CONFIDENTIAL

Table of Contents

List of Figures 4

1 Document Control 5

1.1 Team 5

1.2 List of Changes 5

2 Executive Summary 6

2.1 Overview 6

2.2 Identified Vulnerabilities 6

3 Methodology 8

3.1 Objective 8

3.2 Scope 8

3.3 User Accounts and Permissions 8

4 Findings 9

C1: Server-side template injection in article 404 handler 9

H1: Media upload accepts HTML when declared as an image 10

M1: Reflected cross-site scripting in article 404 handler 11

M2: Session cookies missing Secure and SameSite 12

M3: Public articles API discloses staff account details 13

M4: Unmoderated public comments with no CSRF protection 14

M5: Admin login form has no CSRF token 15

M6: Missing HTTP security headers 16

I1: Contact form never sends a message 17

I2: Framework 404 pages reveal Flask/Werkzeug 18

5 Disclaimer 19

A Appendix 20

A.1 Static Appendix Section 20

A.2 Methodology 20

A.3 Limitations and coverage 20

List of Figures

Figure 1 - Distribution of identified vulnerabilities 7

1 Document Control

1.1 Team

Contact	Details	Role
ClawSec	Autonomous agent	Pentester

1.2 List of Changes

Version	Description	Date
1.0	Final report	Oct 5, 2026

2 Executive Summary

2.1 Overview

DownUnderNewsz operates The Down Under News, an independent online newspaper. This assessment covered the owner-approved public website www.thedownundernews.online only.

Ten issues were confirmed: **one critical**, **one high**, **six medium**, and **two informational**.

The most serious issue is that missing article pages execute template expressions supplied in the URL. This is a critical server-side template injection. Related to the same error page, the site also reflects HTML into the 404 response. A logged-in writer can upload HTML by labelling it as an image. The public articles API exposes staff emails and roles. Session cookies lack Secure and SameSite. Public comments appear immediately without CSRF protection. Security headers are missing. The contact form does not actually send messages.

Highest-priority action: stop evaluating user input in templates, then lock down uploads, the public API, and cookies.

2.2 Identified Vulnerabilities

#	CVSS	Description	Page
C1	9.8	Server-side template injection in article 404 handler	9
H1	7.6	Media upload accepts HTML when declared as an image	10
M1	6.1	Reflected cross-site scripting in article 404 handler	11
M2	5.4	Session cookies missing Secure and SameSite	12
M3	5.3	Public articles API discloses staff account details	13
M4	5.3	Unmoderated public comments with no CSRF protection	14
M5	4.3	Admin login form has no CSRF token	15
M6	4.3	Missing HTTP security headers	16
I1	0.0	Contact form never sends a message	17
I2	0.0	Framework 404 pages reveal Flask/Werkzeug	18

Vulnerability Overview

In the course of this penetration test **1 Critical**, **1 High**, **6 Medium** and **2 Info** vulnerabilities were identified:

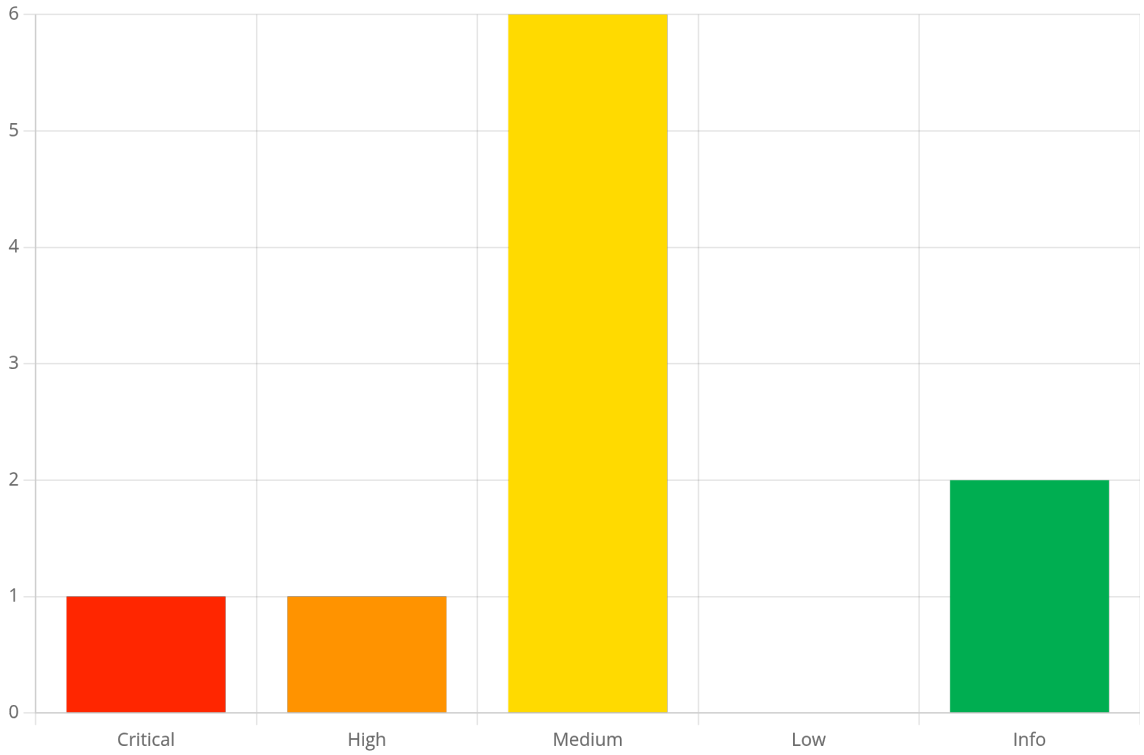


Figure 1 - Distribution of identified vulnerabilities

3 Methodology

This entire vulnerability assessment process was completed using agentic AI and existing LLM models. The purpose of such assessments is to automatically

3.1 Objective

The entire objective of this research is to evaluate the effectiveness of autonomously evaluate security posture for any business available on Google Map without the needs of technical guidance to determine how feasiable, seamless and cost-affective such approach is.

3.2 Scope

The owner authorised a full-scope request. The owner then approved only the main website for testing. Testing used unauthenticated and authenticated web methods with owner-provided dummy accounts (admin, writer, editor). No brute force, denial of service, phishing, malware, or testing of third-party or co-hosted systems was performed.

In-scope assets (owner-approved)

Asset	Description
www.thedownundernews.online	Canonical public hostname
https://www.thedownundernews.online/	Public newspaper site, including same-origin paths and /api/articles

Out of scope (not presented as tested)

- media.thedownundernews.online
- apex thedownundernews.online as a separate target
- 51.161.131.195
- thedownundernews.it.com
- OVH, Spaceship, Google, and jsDelivr third parties

Server-side template injection proof stopped at a Jinja 7-times-7 expression evaluating to 49; no remote-code-execution payload was used. HTML upload proof stopped at HTTP 201 from the www API; the media host was not fetched.

3.3 User Accounts and Permissions

Owner-provided dummy accounts were used for authenticated testing. Passwords are not included in this report.

- admin
- writer
- editor

4 Findings

C1: Server-side template injection in article 404 handler	
Score	9.8 (Critical)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Target	https://www.thedownundernews.online/article/<slug>
References	• https://owasp.org/www-community/attacks/Server-Side_Template_Injection • https://cwe.mitre.org/data/definitions/1336.html

Overview

Missing article pages evaluate attacker-controlled template expressions. A request using the Jinja expression that multiplies 7 by 7 in the article path returned HTML saying the page was not found for 49, proving the server executed the expression. This class of flaw in a Python/Jinja application commonly leads to full server takeover. Further exploitation was stopped once this proof was obtained.

Details

Unauthenticated GET to `/article/` with a Jinja arithmetic expression (seven times seven inside template delimiters) on https://www.thedownundernews.online returned HTTP 404 with Content-Type text/html and body exactly: `<h1>404 - Page not found for 49.`

The arithmetic was evaluated server-side rather than echoed as the literal template expression. Combined with HTML rendering of the same slug (see reflected XSS finding), the 404 handler treats the article name as a template, not as plain text. An attacker who can request a crafted URL can run template code on the newspaper website without logging in.

Recommendation

Stop rendering user-supplied path text through the template engine. Use a static 404 template and pass the slug as a safely escaped variable only. Patch and redeploy immediately, then review all other user-influenced strings for the same pattern.

H1: Media upload accepts HTML when declared as an image	
Score	7.6 (High)
Vector string	CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:L/A:N
Target	https://www.thedownundernews.online/api/admin/media/upload
References	• https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload • https://cwe.mitre.org/data/definitions/434.html

Overview

Staff upload is supposed to allow images and documents only. Sending a small HTML file while labelling it as PNG was accepted and stored with a .html name. Direct HTML was rejected. A logged-in writer can therefore plant HTML that the media library will treat as a file. Execution of that HTML on the separate media host was not verified because that host was out of this assessment's approved scope.

Details

POST /api/admin/media/upload as the writer account:

- file type text/html was rejected with File type 'text/html' is not allowed
- image/svg+xml was rejected
- the same HTML bytes with Content-Type image/png and filename clawsec-proof.html returned HTTP 201 and a URL ending in .html on the media host

The Media Library UI already listed prior xss.html and xss.svg files, which is consistent with dangerous types having been stored. The in-scope issue is the www upload API trusting the client content type instead of inspecting content and extension.

Recommendation

Allow only a fixed list of types after server-side content inspection, not the client Content-Type. Do not keep the original .html extension. Serve uploaded files from a different domain with Content-Disposition: attachment and a restrictive CSP. Remove existing html/svg uploads after review.

M1: Reflected cross-site scripting in article 404 handler	
Score	6.1 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N
Target	https://www.thedownundernews.online/article/<slug>
References	• https://owasp.org/www-community/attacks/xss/ • https://cwe.mitre.org/data/definitions/79.html

Overview

If someone visits a crafted missing-article link, the site inserts that link text into the page as live HTML. A proof request placed a raw image tag with JavaScript in the 404 heading. Session cookies are HttpOnly so they cannot be read by script, but the script still runs in the visitor's browser on the newspaper site.

Details

GET https://www.thedownundernews.online/article/xss-test"><img src=x onerror=alert(1)> returned HTTP 404 text/html with body: 404 - Page not found for xss-test"><img src=x onerror=alert(1)>.

The payload was not encoded. Search pages do encode the same characters, so this is specific to the article 404 path. Same root cause as the template injection finding: unsanitised slug output.

Recommendation

HTML-encode all user-controlled text in error pages. Add a Content-Security-Policy that disallows inline script. Fix together with the template injection issue.

M2: Session cookies missing Secure and SameSite	
Score	5.4 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Target	https://www.thedownundernews.online/admin/login
References	• https://owasp.org/www-community/controls/SecureCookieAttribute • https://cwe.mitre.org/data/definitions/1275.html • https://cwe.mitre.org/data/definitions/614.html

Overview

After login, the site sets an access token cookie that is HttpOnly but not marked Secure or SameSite. A Flask flash session cookie used after posting a comment has the same gap. The token can be sent over plain HTTP and used in cross-site requests.

Details

POST /admin/login with a valid test account returned Set-Cookie: access_token_cookie=...; HttpOnly; Path=/ with no Secure and no SameSite. HTTP http://www.thedownundernews.online/ redirects to HTTPS (301) but does not send HSTS. Comment posting set a session cookie as HttpOnly; Path=/ only. JWT algorithm observed on the access cookie was HS256 (value not recorded in this report).

Recommendation

Set Secure; SameSite=Lax or Strict; HttpOnly on all session cookies. Enable HSTS on HTTPS responses. Keep cookie names and paths as they are so existing logout still works.

M3: Public articles API discloses staff account details	
Score	5.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target	https://www.thedownundernews.online/api/articles
References	• https://owasp.org/API-Security/editions/2023/en/0xa3-broken-object-property-level-authorization/ • https://cwe.mitre.org/data/definitions/213.html

Overview

The public news feed includes each author's email address, username, role, and whether the account is active. Anyone can collect staff identities and mailbox names without logging in. That helps phishing and password-guessing against the admin panel.

Details

Unauthenticated GET /api/articles?limit=5 returned JSON for published articles. Each author object included email, username, role (admin), is_active, first_name, last_name, id, and created_at. Example fields observed for the site administrator account (email not repeated here). This is more than a public byline requires. CORS allows https://thedownundernews.online without credentials; origins are not reflected.

Recommendation

Return only public byline fields (display name). Keep email, username, role, and account status for authenticated admin APIs. Review other public JSON endpoints the same way.

M4: Unmoderated public comments with no CSRF protection	
Score	5.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N
Target	https://www.thedownundernews.online/article/welcome-to-the-down-under-news/comment
References	• https://owasp.org/www-community/attacks/csrf • https://cwe.mitre.org/data/definitions/352.html

Overview

Anyone can post a comment that shows on the article immediately. There is no login, no captcha, no CSRF token, and the page tells users comments appear at once. HTML in the comment was encoded, so this is not stored scripting, but names can be faked and the article can be spammed.

Details

The article page form POSTs to /article//comment with author_name, author_email, and content. No hidden token. POST of a proof comment as ClawSecAssess redirected to #comments with a success flash. The published page showed the name and encoded comment text; the email was not displayed. The notice text says comments appear immediately. Writer role received 403 on /admin/comments; editor can open the comments admin page.

Recommendation

Require moderation before comments go live, or at least rate-limit and captcha. Add a CSRF token. Consider hiding the form from unauthenticated users if that matches editorial policy.

M5: Admin login form has no CSRF token	
Score	4.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N
Target	https://www.thedownundernews.online/admin/login
References	• https://owasp.org/www-community/attacks/csrf • https://cwe.mitre.org/data/definitions/352.html

Overview

The staff login page posts username and password with no anti-CSRF field. Together with cookies that lack SameSite, a visitor who is tricked into submitting a login form from another site could have a session created in their browser.

Details

GET /admin returned the Admin Login page. The form posts to /admin/login with username and password only. Successful login is 302 to /admin/dashboard and sets access_token_cookie. JSON admin APIs use Content-Type application/json, which browsers do not send as simple form CSRF; the login endpoint is a conventional form POST and is the practical CSRF risk.

Recommendation

Add a CSRF token to /admin/login and all cookie-authenticated form posts. Set SameSite on the session cookie as in the cookie finding.

M6: Missing HTTP security headers	
Score	4.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:N
Target	https://www.thedownundernews.online/
References	• https://owasp.org/www-project-secure-headers/ • https://cwe.mitre.org/data/definitions/693.html

Overview

The live site does not send the usual browser protections: no HSTS, no Content-Security-Policy, no clickjacking header, no nosniff, and no Referrer-Policy. Homepage responses only included Server, Date, Content-Type, Content-Length, and Connection.

Details

GET https://www.thedownundernews.online/ returned HTTP 200 with nginx and no Content-Security-Policy, Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, or Permissions-Policy. This makes reflected XSS and clickjacking easier and allows HTTP reuse without HSTS pinning.

Recommendation

Add HSTS, CSP, X-Frame-Options or frame-ancestors, X-Content-Type-Options: nosniff, and Referrer-Policy in nginx or the application. Start CSP in report-only if needed, then enforce.

I1: Contact form never sends a message	
Score	0.0 (Info)
Vector string	N/A
Target	https://www.thedownundernews.online/contact
References	-

Overview

The Contact Us form only shows a thank-you message in the browser. It does not send data to the server, so reader messages are not actually received.

Details

/contact includes a form with name, email, subject, and message. Inline script calls preventDefault, displays #contactSuccess, and resets the form. No fetch or POST to an API. This is a reliability/integrity issue for a public contact channel, not an injection flaw.

Recommendation

Wire the form to a server endpoint with CSRF protection, validation, and spam controls, or replace it with a working mailbox link only.

I2: Framework 404 pages reveal Flask/Werkzeug	
Score	0.0 (Info)
Vector string	N/A
Target	https://www.thedownundernews.online/
References	-

Overview

Some missing URLs return the default Flask/Werkzeug not-found page, which tells an attacker the site is a Python Flask app.

Details

Requests such as /robots.txt, /api/users, and several unknown paths returned HTML: The requested URL was not found on the server. If you entered the URL manually please check your spelling and try again. Custom article 404s are different one-line HTML. Server header is nginx.

Recommendation

Replace default framework error pages with the site's own 404 page. Do not expose stack traces in production.

5 Disclaimer

The purpose of this research project is to help evaluating the seamlessness, effectiveness and cost-benefit ratio of autonomously performing vulnerabilty assessment using agentic AI. I do not take any responsibility upon any misuse or abuse of such tool where it can face significant legal actions.

A Appendix

A.1 Static Appendix Section

A.2 Methodology

Testing was performed against the owner-approved public website only.

- Unauthenticated web testing of public pages, forms, and the same-origin articles API.
- Authenticated web testing with owner-provided dummy accounts for admin, writer, and editor roles.
- Non-destructive injection checks, including a server-side template injection proof that stopped at a Jinja 7-times-7 expression evaluating to 49.
- Upload testing against the www media upload API; proof stopped at HTTP 201. The media host was not fetched.
- Review of session cookies and HTTP security headers on www.thedownundernews.online.

No brute force, denial of service, phishing, malware, or testing of third-party or co-hosted systems was performed. Timezone context from server headers was GMT on 2026-10-04. Assessment dates: authorisation and testing on 2026-10-04; reporting on 2026-10-04 / 2026-10-05.

A.3 Limitations and coverage

Only www.thedownundernews.online was in scope. The media server, the claimed it.com domain, and host-wide IP scans were not approved and were not tested.

Observed during testing, and not reported as confirmed vulnerabilities unless listed in the findings:

- SQL injection was not evidenced on search.
- A writer could not publish (status was forced to draft) or edit others' articles via the API.
- Search reflected input was HTML-encoded.
- Comment XSS was encoded.
- The contact form does not submit (recorded as informational).